

Microsoft Certified: Security Operations Analyst Associate

Course

Defend against cyberthreats with Microsoft's security operations platform

---

Module 1

Mitigate threats using Microsoft Defender XDR

Modules in this learning path

COURSE 4

Manage Microsoft Entra Identity Protection

Introduction

Protecting users' identity by monitoring their usage and sign-in patterns ensures a secure cloud solution. Explore how to design and implement Microsoft Entra Identity Protection.

Learning objectives

In this module, you will:

Review Identity Protection basics.

Implement and manage a user risk policy.

Implement and manage sign-in risk policies.

Implement and manage multifactor authentication (MFA) registration policy.

Monitor, investigate, and remediate elevated risky users.

Explore Microsoft Defender for Identity

Review identity protection basics

Identity Protection is a service that enables organizations to view the security posture of any account. Organizations can accomplish three key tasks:

Automate the detection and remediation of identity-based risks.

Investigate risks using data in the portal.

Export risk detection data to third-party utilities for further analysis.

Always remember that Microsoft Entra Identity Protection requires a Microsoft Entra ID Premium P2 license to operate. Licensing is covered in more detail in a later unit.

Identity Protection uses the knowledge Microsoft has gained from its position in organizations with Microsoft Entra ID, the consumer space with Microsoft Accounts, and in gaming with Xbox to protect your users. Microsoft analyzes 6.5 trillion signals per day to identify and protect customers from threats.

The signals generated by and fed to Identity Protection can be further fed into tools like Conditional Access to make access decisions or fed back to a security information and event management (SIEM) tool for further investigation based on your organization's enforced policies.

Risk detection and remediation

Identity Protection identifies risks in the following classifications:

Risk detection type	Description
Anonymous IP address	Sign in from an anonymous IP address (for example: Tor browser, anonymizer VPNs).
Atypical travel	Sign in from an atypical location based on the user's recent sign ins.
Malicious IP address	Sign in from a malicious IP address.
Unfamiliar sign in properties	Sign in with properties we've not seen recently for the given user.
Leaked credentials	Indicates that the user's valid credentials have been leaked.
Password spray	Indicates that multiple usernames are being attacked using common passwords in a unified brute-force manner.
Microsoft Entra threat intelligence	Microsoft's internal and external threat intelligence sources have identified a known attack pattern.
Anomalous token	Detects unusual characteristics in a token, such as an unusual token lifetime or a token replayed from an unfamiliar location.
Token issuer anomaly	Detects when the SAML token issuer for the associated SAML token is potentially compromised.
Suspicious browser	Detects anomalous sign-in activity across multiple tenants from the same browser.
Verified threat actor IP	Detects sign-in activity from IP addresses known to be associated with verified threat actors.
New country	This detection is discovered by Microsoft Defender for Cloud Apps (MDCA).
Activity from anonymous IP address	This detection is discovered by MDCA.
Suspicious inbox forwarding	This detection is discovered by MDCA.

Permissions

Identity Protection requires users be a Security Reader, Security Operator, Security Administrator, Global Reader Administrator in order to access.

Role	Can do	Can't do
Security Administrator	Full access to Identity Protection	Reset password for a user
Security Operator	View all Identity Protection reports and Overview screen, Dismiss user risk, confirm safe sign-in, confirm compromise	Configure or change policies, Reset password for a user, Configure alerts
Security Reader	View all Identity Protection reports and Overview screen	Configure or change policies, Reset password for a user, Configure alerts, Give feedback on detections

The Security Operator role can't access the Risky sign-ins report. Conditional Access Administrators can also create policies that factor in sign-in risk as a condition.

License requirements

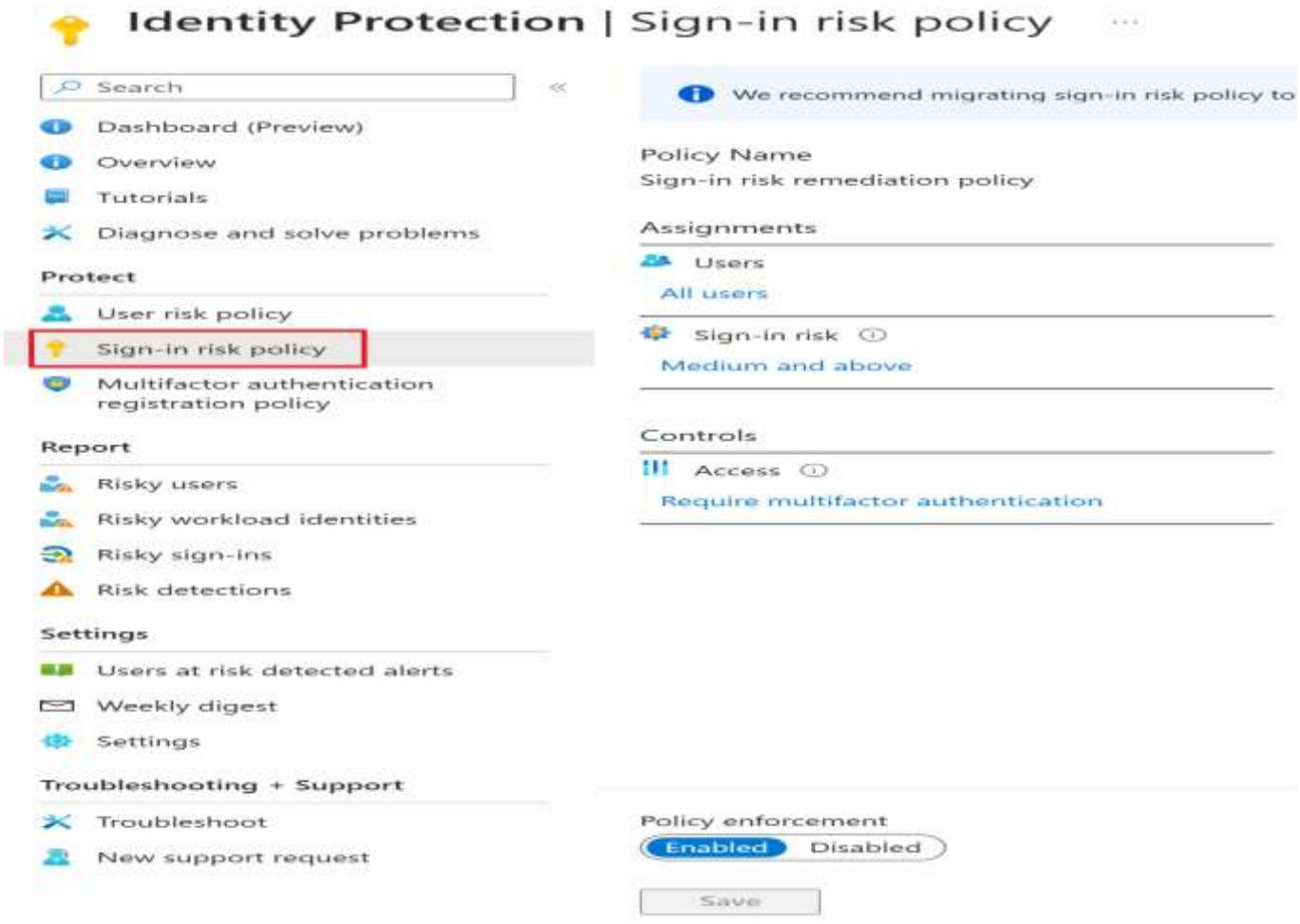
Using this feature requires a Microsoft Entra ID Premium P2 license.

Capability	Details	Microsoft Entra ID Free / Microsoft 365 Apps	Microsoft Entra ID Premium P1	Microsoft Entra ID Premium P2
Risk policies	User risk policy (via Identity Protection)	No	No	Yes
Risk policies	Sign-in risk policy (via Identity Protection or Conditional Access)	No	No	Yes
Security reports	Overview	No	No	Yes
Security reports	Risky users	Limited information. Only users with medium and high risk are shown. No details drawer or risk history.	Limited information. Only users with medium and high risk are shown. No details drawer or risk history.	Full access
Security reports	Risky sign ins	Limited information. No risk detail or risk level is shown.	Limited information. No risk detail or risk level is shown.	Full access
Security reports	Risk detections	No	Limited information. No details drawer.	Full access
Notifications	Users at risk detected alerts	No	No	Yes
Notifications	Weekly digest	No	No	Yes
	MFA registration policy	No	No	Yes

Implement and manage user risk policy

There are two risk policies that can be enabled in the directory:

Sign-in risk policy: The sign-in risk policy detects suspicious actions that come along with the sign-in. It's focused on the sign-in activity itself and analyzes the probability that the sign-in was performed by some other than the user.



User risk policy: The user risk policy detects the probability that a user account has been compromised by detecting risk events that are atypical of a user's behavior.

Both policies work to automate the response to risk detections in your environment and allow users to self-remediate when risk is detected.

Prerequisites

If your organization wants to allow users to self-remediate when risks are detected, users must be registered for both self-service password reset and multifactor authentication. We recommend enabling the combined security information registration experience. Allowing users to self-remediate gets them back to a productive state more quickly without requiring administrator intervention. Administrators can still see these events and investigate them after the fact.

Choosing acceptable risk levels

Organizations must decide the level of risk they're willing to accept, balancing user experience and security posture.

Microsoft's recommendation is to set the user risk policy threshold to High and the sign-in risk policy to Medium and higher.

Choosing a High threshold reduces the number of times a policy is triggered and minimizes the challenge to users. However, it excludes Low and Medium risk detections from the policy, which does not block an attacker from exploiting a compromised identity. Selecting a Low threshold introduces extra user interrupts but increased security posture.

Exclusions

All of the policies allow for excluding users such as your emergency access or break-glass administrator accounts. Organizations determine when they need to exclude other accounts from specific policies based on the way the accounts are used. All exclusions should be reviewed regularly to see if they're still applicable.

Configured trusted network locations are used by Identity Protection in some risk detections to reduce false positives.

Exercise enable sign-in risk policy

Enable user risk policy

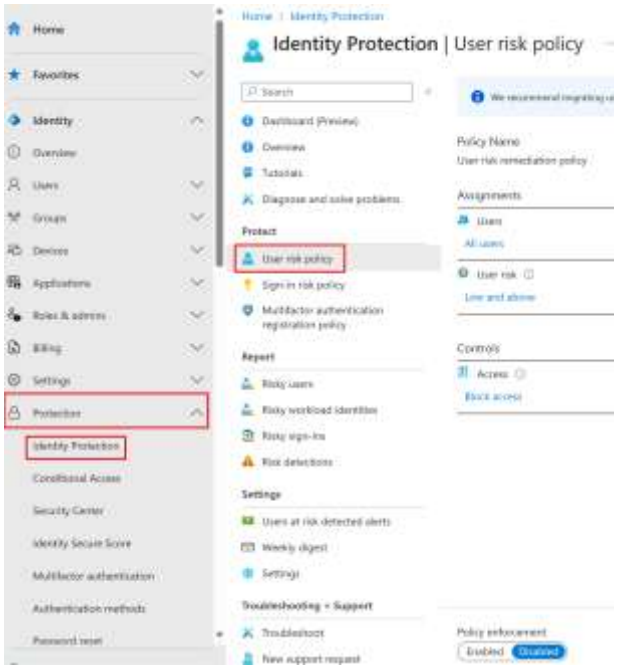
Sign in to the Microsoft Entra admin center using a Global administrator account.

Open the portal menu and then select Identity.

On the Identity menu, select Protection.

On the Security blade, in the left navigation, select Identity protection.

In the Identity protection blade, in the left navigation, select User risk policy.



Under Assignments, select All users and review the available options. You can select from All users or Select individuals and groups if limiting your rollout. Additionally, you can choose to exclude users from the policy.

Under User risk, select Low and above.

In the User risk pane, select High and then select Done.

Under Controls, then Access, and then select Block access.

In the Access pane, review the available options.

Tip

Microsoft's recommendation is to Allow access and Require password change.

Select the Require password change check box and then select Done.

Under Enforce Policy, select On and then select Save.

Enable sign-in risk policy

On the Identity protection blade, in the left navigation, select Sign-in risk policy.

As with the User risk policy, the Sign-in risk policy can be assigned to users and groups and allows you to exclude users from the policy.

Under Sign-in risk, select Medium and above.

In the Sign-in risk pane, select High and then select Done.

Under Controls, then Access, and then select Block access.

Select the Require multifactor authentication check box and then select Done.

Under Enforce Policy, select On and then select Save.

Exercise configure Microsoft Entra multifactor authentication registration policy

Completed100 XP

5 minutes

Policy configuration

Multifactor authentication provides a means to verify who you are using more than just a username and password. It provides a second layer of security to user sign-ins. For users to be able to respond to MFA prompts, they must first register for multifactor authentication.

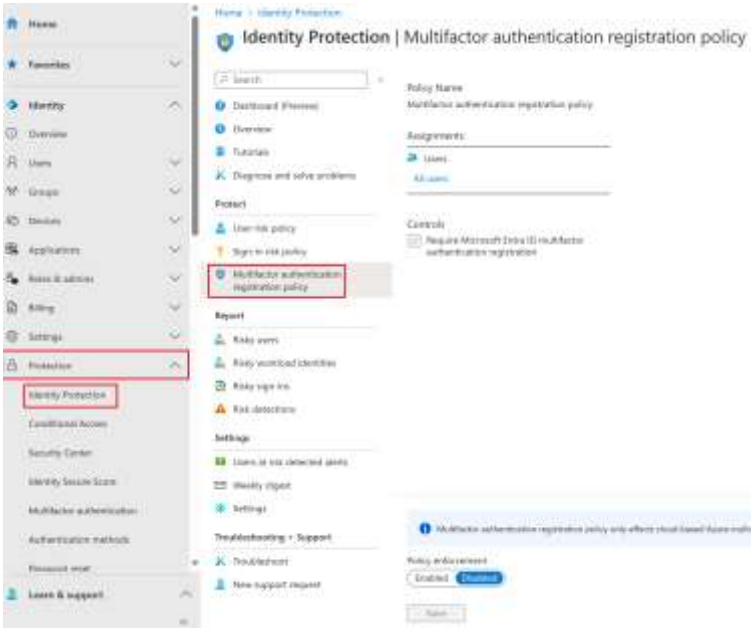
Sign in to the Microsoft Entra admin center using a Global administrator account.

Open the portal menu and then select Identity.

On the Identity men, select Protection.

On the Security blade, in the left navigation, select Identity protection.

In the Identity protection blade, in the left navigation, select Multifactor authentication registration policy.



Under Assignments, select All users and review the available options. You can select from All users or Select individuals and groups if limiting your rollout. Additionally, you can choose to exclude users from the policy.

Under Controls, notice that the Require Microsoft Entra ID multifactor authentication registration is selected and cannot be changed.

Under Enforce Policy, select Enabled and then select Save.

Monitor, investigate, and remediate elevated risky users

Investigate risk

Identity Protection provides organizations with three reports they can use to investigate identity risks in their environment: risky users, risky sign-ins, and risk detections. Investigating events is key to better understanding and identifying any weak points in your security strategy.

All three reports allow for downloading of events in .CSV format for further analysis outside of the Azure portal. The risky users and risky sign-ins reports allow for downloading the most recent 2,500 entries, while the risk detections report allows for downloading the most recent 5,000 records.

Organizations can take advantage of the Microsoft Graph API integrations to aggregate data with other sources they have access to as an organization.

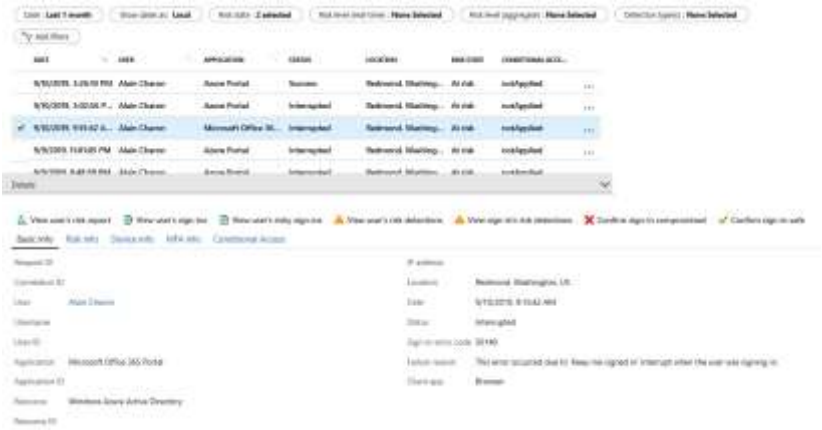
You can find the three reports in the Microsoft Entra admin center, then Identity, and then Protection - Identity Protection.

Navigating the reports

Each report launches with a list of all detections for the period shown at the top of the report. Each report allows for the addition or removal of columns based on administrator preference. Administrators can choose to download the data in .CSV or .JSON format. Reports can be filtered using the filters across the top of the report.

Selecting individual entries enables more entries at the top of the report, such as the ability to confirm a sign-in as compromised or safe, confirm a user as compromised, or dismiss user risk.

Selecting individual entries expands a details window below the detections. The details view allows administrators to investigate and perform actions on each detection.



Risky users

With the information provided by the risky users report, administrators can find:

Which users are at risk, have had risk remediated, or have had risk dismissed?

Details about detections.

History of all risky sign-ins.

Risk history.

Administrators can then choose to take action on these events. They can choose to:

Reset the user password.

Confirm user compromise.

Dismiss user risk.

Block user from signing in.

Investigate in Microsoft Defender for Identity.

Risky sign-ins

The risky sign-ins report contains filterable data for up to the past 30 days (one month).

With the information provided by the risky sign-ins report, administrators can find:

Which sign-ins are classified as at risk, confirmed compromised, confirmed safe, dismissed, or remediated.

Real-time and aggregate risk levels associated with sign-in attempts.

Detection types triggered.

Conditional Access policies applied.

MFA details.

Device information.

Application information.

Location information.

Administrators can then choose to take action on these events. Administrators can choose to:

Confirm sign-in compromise.

Confirm sign-in safe.

Risk detections

The risk detections report contains filterable data for up to the past 90 days (three months).

With the information provided by the risk detections report, administrators can find:

Information about each risk detection including type.

Other risks triggered at the same time.

Sign-in attempt location.

Administrators can then choose to return to the user's risk or sign-ins report to take actions based on information gathered.

The risk detection report also provides a clickable link to the detection in the Microsoft Defender for Cloud Apps (MDCA) portal where you can view more logs and alerts.

Note

Our system detects that the risk event that contributed to the risk user risk score was a false positive or that the user risk was remediated with policy enforcement such as completing an MFA prompt or secure password change. Therefore, our system dismisses the risk state, and a risk detail of “AI confirmed sign-in safe” will surface and no longer contribute to the user’s risk.

Remediate risks and unblock users

After completing your investigation, you'll want to take action to remediate the risk or unblock users. Organizations also have the option to enable automated remediation using their risk policies. Organizations should try to close all risk detections that they're presented with in a time period your organization is comfortable with. Microsoft recommends closing events as soon as possible because time matters when working with risk.

Remediation

All active risk detections contribute to the calculation of a value called user risk level. The user risk level is an indicator (low, medium, high) for the probability that an account has been compromised. As an administrator, you want to get all risk detections closed, so that the affected users are no longer at risk.

Some risk detections are marked by Identity Protection as "Closed (system)" because the events were no longer determined to be risky.

Administrators have the following options to remediate:

Self-remediation with risk policy.

Manual password reset.

Dismiss user risk.

Close individual risk detections manually.

Self-remediation with risk policy

If you allow users to self-remediate, with multifactor authentication (MFA) and self-service password reset (SSPR) in your risk policies, they can unblock themselves when risk is detected. These detections are then considered closed. Users must have previously registered for MFA and SSPR in order to use when risk is detected.

Some detections don't raise risk to the level where a user self-remediation would be required, but administrators should still evaluate these detections. Administrators determine that other measures are necessary, such as blocking access from locations or lowering the acceptable risk in their policies.

Manual password reset

If requiring a password reset using a user risk policy isn't an option, administrators can close all risk detections for a user with a manual password reset.

Administrators are given two options when resetting a password for their users:

Generate a temporary password - By generating a temporary password, you can immediately bring an identity back into a safe state. This method requires contacting the affected users since they need to know what the temporary password is. Because the password is temporary, the user is prompted to change the password to something new during the next sign-in.

Require the user to reset password - Requiring the users to reset passwords enables self-recovery without contacting help desk or an administrator. This method only applies to users who are registered for MFA and SSPR. For users who haven't been registered, this option isn't available.

Dismiss user risk

If a password reset isn't an option for you because, for example, the user has been deleted, you can choose to dismiss user risk detections.

When you select Dismiss user risk, all events are closed and the affected user is no longer at risk. However, because this method doesn't affect the existing password, it doesn't bring the related identity back into a safe state.

Close individual risk detections manually

By closing individual risk detections manually, you can lower the user risk level. Typically, risk detections are closed manually in response to a related investigation, such as when talking to a user reveals that an active risk detection isn't required anymore.

When closing risk detections manually, you can choose to take any of the following actions to change the status of a risk detection:

Confirm user compromised.

Dismiss user risk.

Confirm sign-in safe.

Confirm sign-in compromised.

Unblocking users

An administrator chooses to block a sign-in based on their risk policy or investigations. A block occurs based on either sign-in or user risk.

Unblocking based on user risk

To unblock an account blocked due to user risk, administrators have the following options:

Reset password - You can reset the user's password.

Dismiss user risk - The user risk policy blocks a user if the configured user risk level for blocking access has been reached. You can reduce a user's risk level by dismissing user risk or manually closing reported risk detections.

Exclude the user from policy - If you think that the current configuration of your sign-in policy is causing issues for specific users, you can exclude the users from it.

Disable policy - If you think that your policy configuration is causing issues for all your users, you can disable the policy.

Unblocking based on sign-in risk

To unblock an account based on sign-in risk, administrators have the following options:

Sign in from a familiar location or device - A common reason for blocked suspicious sign-ins are sign-in attempts from unfamiliar locations or devices. Your users can quickly determine whether this reason is the blocking reason by trying to sign in from a familiar location or device.

Exclude the user from policy - If you think that the current configuration of your sign-in policy is causing issues for specific users, you can exclude the users from it.

Disable policy - If you think that your policy configuration is causing issues for all your users, you can disable the policy.

PowerShell preview

Using the Microsoft Graph PowerShell SDK Preview module, organizations can manage risk using PowerShell. The preview modules and sample code are located in the Azure GitHub repo.

Use the Microsoft Graph API

Microsoft Graph is the Microsoft unified API endpoint and the home of Microsoft Entra Identity Protection APIs. There are three APIs that expose information about risky users and sign-ins: riskDetection, riskyUsers, and signIn.

riskDetectionallows you to query Microsoft Graph for a list of both user and sign-in linked risk detections and associated information about the detection.

riskyUsersallows you to query Microsoft Graph for information about users that Identity Protection detected as being risky.

signIn allows you to query Microsoft Graph for information on Microsoft Entra ID sign-ins with specific properties related to risk state, detail, and level.

This section gets you started with connecting to the Microsoft Graph and querying these APIs. For an in-depth introduction, full documentation, and access to the Graph Explorer, see the Microsoft Graph site (https://graph.microsoft.io/) or the specific reference documentation for the riskDetection, riskyUsers, and signIn APIs.

Connect to Microsoft Graph

There are four steps to accessing Identity Protection data through Microsoft Graph: retrieve your domain name, create a new app registration, configure API permissions, and configure a valid credential.

Retrieve your domain name

Sign in to the Microsoft Entra admin center.

Browse to Identity, then open Settings, and select Domain names.

Take note of the .onmicrosoft.com domain. You need this information in a later step.

Create a new app registration

In the Microsoft Entra admin center, browse to Identity and Applications, then App registrations.

Select New registration.

On the Create page, perform the following steps:

In the Name textbox, type a name for your application (for example: Microsoft Entra Risk Detection API).

Under Supported account types, select the type of accounts that use the APIs.

Select Register.

Copy the Application ID.

Configure API permissions

From the Application you created, select API permissions.

On the Configured permissions page, in the toolbar on the top, select Add a permission.

On the Add API access page, choose Select an API.

On the Select an API page, select Microsoft Graph, and then select Select.

On the Request API permissions page:

Select Application permissions.

Select the checkboxes next to IdentityRiskEvent.Read.All and IdentityRiskyUser.Read.All.

Select Add permissions.

Select Grant admin consent for domain.

Configure a valid credential

From the Application you created, select Certificates and secrets.

Under Client secrets, select New client secret.

Give the client secret a Description and set the expiration time period according to your organizational policies.

Select Add.

Note

If you lose this key, you have to return to this section and create a new key. Keep this key a secret: Anyone who has it can access your data.

Authenticate to Microsoft Graph and query the Identity Protection risk detections API

At this point, you should have:

The name of your tenant's domain

The Application (client) ID

The client secret or certificate

To authenticate, send a post request to https://login.microsoft.com with the following parameters in the body:

grant_type: client_credentials

resource: https://graph.microsoft.com

client_id:

client_secret:

If successful, this request returns an authentication token. To call the API, create a header with the following parameter:

HTTP

Authorization`="<token_type> <access_token>"

When authenticating, you can find the token type and access token in the returned token.

Send this header as a request to the following API
URL: https://graph.microsoft.com/v1.0/identityProtection/riskDetections.

The response, if successful, is a collection of identity risk detections and associated data in the OData JSON format, which can be parsed and handled as you see fit.

Sample

This sample shows the use of a shared secret to authenticate. In a production environment, storing secrets in code is frowned upon. Organizations can use managed identities for Azure resources to secure these credentials.

Here's sample code for authenticating and calling the API using PowerShell. Just add your client ID, the secret key, and the tenant domain.

PowerShell

```
$ClientID      = "<your client ID here>"        # Should be a ~36 hex character string; insert your info here

$ClientSecret  = "<your client secret here>"    # Should be a ~44 character string; insert your info here

$tenantdomain  = "<your tenant domain here>"    # For example, contoso.onmicrosoft.com

$loginURL      = "https://login.microsoft.com"

$resource      = "https://graph.microsoft.com"

$body          = @{grant_type="client_credentials";resource=$resource;client_id=$ClientID;client_secret=$ClientSecret}

$oauth         = Invoke-RestMethod -Method Post -Uri $loginURL/$tenantdomain/oauth2/token?api-version=1.0 -Body $body

Write-Output $oauth

if ($oauth.access_token -ne $null) {

    $headerParams = @{'Authorization'="$($oauth.token_type) $($oauth.access_token)"}

    $url = "https://graph.microsoft.com/v1.0/identityProtection/riskDetections"

    Write-Output $url
```

```
    $myReport = (Invoke-WebRequest -UseBasicParsing -Headers $headerParams -Uri $url)

    foreach ($event in ($myReport.Content | ConvertFrom-Json).value) {

        Write-Output $event

    }

} else {

    Write-Host "ERROR: No Access Token"

}
```

Get all of the offline risk detections (riskDetection API)

With Identity Protection sign-in risk policies, you can apply conditions when risk is detected in real time. But what about detections that are discovered offline? To understand what detections occurred offline and, thus, wouldn't have triggered the sign-in risk policy, you can query the riskDetection API.

HTTP

GET https://graph.microsoft.com/v1.0/identityProtection/riskDetections?$filter=detectionTimingType eq 'offline'

Get all of the users who successfully passed an MFA challenge triggered by risky sign-ins policy (riskyUsers API)

To understand the value Identity Protection risk-based policies have on your organization, you can query all of the users who successfully passed an MFA challenge triggered by a risky sign-ins policy. This information can help you understand which users Identity Protection has falsely detected as a risk and which of your legitimate users are performing actions that the AI deems risky.

HTTP

GET https://graph.microsoft.com/v1.0/identityProtection/riskyUsers?$filter=riskDetail eq 'userPassedMFADrivenByRiskBasedPolicy'

Implement security for workload identities

Microsoft Entra Identity Protection has historically protected users in detecting, investigating, and remediating identity-based risks. Identity protection has extended these capabilities to workload identities to protect applications, service principals, and Managed Identities.

A workload identity is an identity that allows an application or service principal access to resources, sometimes in the context of a user. These workload identities differ from traditional user accounts as they:

Can’t perform multifactor authentication.

Often have no formal lifecycle process.

Need to store their credentials or secrets somewhere.

These differences make workload identities harder to manage and put them at higher risk for compromise.

Requirements to use workload identity protection

To make use of workload identity risk, including the Risky workload identities blade and the Workload identity detections tab in the Risk detections blade, in the Microsoft Entra admin center you must have the following.

Microsoft Entra ID Premium P2 licensing

Logged in user must be assigned either:

Security administrator

Security operator

Security reader

What types of risks are detected?

Detection name	Detection type	Description
Microsoft Entra threat intelligence	Offline	This risk detection indicates some activity that's consistent with known attack patterns based on Microsoft's internal and external threat intelligence sources.
Suspicious Sign-ins	Offline	This risk detection indicates sign-in properties or patterns that are unusual for this service principal.
		The detection learns the baselines sign-in behavior for workload identities in your tenant in between 2 and 60 days, and fires if one or more of the following unfamiliar properties appear during a later sign-in: IP address / ASN, target resource, user agent, hosting/non-hosting IP change, IP country, credential type.
Unusual addition of credentials to an OAuth app	Offline	This detection is discovered by Microsoft Defender for Cloud Apps. This detection identifies the suspicious addition of privileged credentials to an OAuth app. This can indicate that an attacker has compromised the app, and is using it for malicious activity.
Admin confirmed account compromised	Offline	This detection indicates an admin has selected 'Confirm compromised' in the Risky Workload Identities UI or using riskyServicePrincipals API. To see which admin has confirmed this account compromised, check the account's risk history (via UI or API).
Leaked Credentials	Offline	This risk detection indicates that the account's valid credentials have been leaked. This leak can occur when someone checks in the credentials in public code artifact on GitHub, or when the credentials are leaked through a data breach.

Add conditional access protection

Using Conditional Access for workload identities, you can block access for specific accounts you choose when Identity Protection marks them "at risk." Policy can be applied to single-tenant service principals that have been registered in your tenant. Third-party SaaS, multi-tenanted apps, and managed identities are out of scope.

Explore Microsoft Defender for Identity

Microsoft Defender for Identity (formerly Azure Advanced Threat Protection) is a cloud-based security solution. Defender for identity uses your on-premises Active Directory signals to identify, detect, and investigate advanced threats, compromised identities, and malicious insider actions directed at your organization. Defender for Identity enables SecOp analysts and security professionals struggling to detect advanced attacks in hybrid environments to:

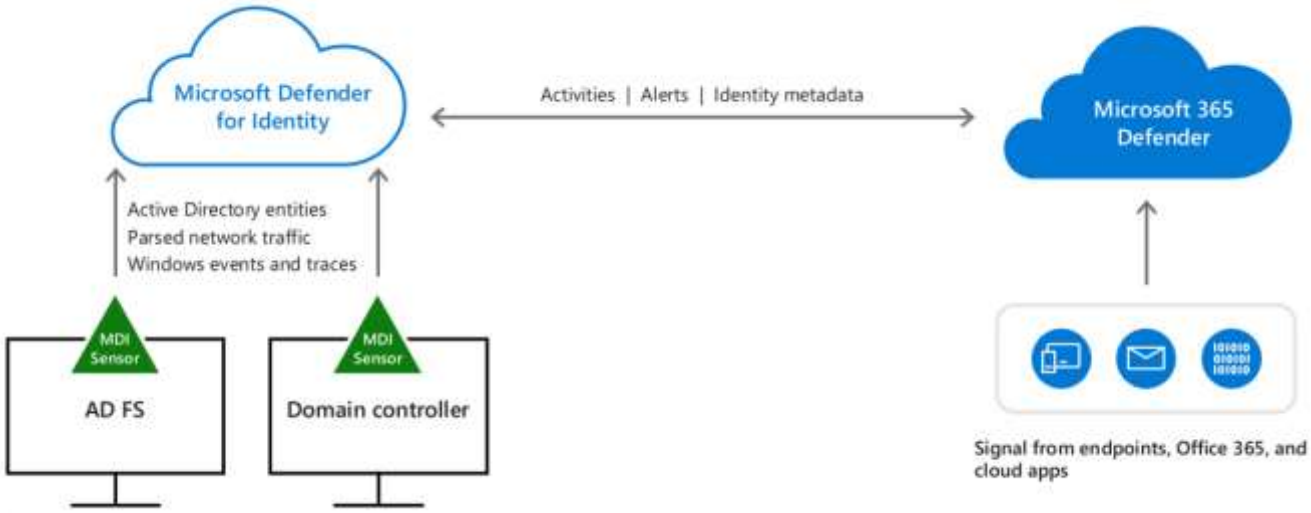
Monitor users, entity behavior, and activities with learning-based analytics

Protect user identities and credentials stored in Active Directory

Identify and investigate suspicious user activities and advanced attacks throughout the kill chain

Provide clear incident information on a simple timeline for fast triage

Process flow for Defender for Identity



Defender for Identity consists of the following components:

Microsoft Defender portal - Defender for Identity is managed through the Microsoft Defender portal (security.microsoft.com). The portal displays data received from Defender for Identity sensors and enables you to monitor, manage, and investigate threats in your network environment.

Defender for Identity sensor - Defender for Identity sensors can be directly installed on the following servers:

Domain controllers: The sensor directly monitors domain controller traffic, without the need for a dedicated server, or configuration of port mirroring.

Active Directory Federated Services (AD FS): The sensor directly monitors network traffic and authentication events.

Defender for Identity cloud service - Defender for Identity cloud service runs on Azure infrastructure and is currently deployed in the US, Europe, and Asia. Defender for Identity cloud service is connected to Microsoft's threat intelligence.

Explore the Identity Risk Management Agent

The Identity Risk Management Agent in Microsoft Entra ID Protection provides proactive risk management capabilities by analyzing user behavior. The agent then suggests actions to mitigate potential identity risks. You can configure the settings to meet your organization's needs. By using a Large Language Model, the agent helps security administrators review and respond to risky activities before they lead to security incidents.

Prerequisites

You must have at least the Microsoft Entra ID P2 license.

You must have available security compute units (SCU).

You must have the appropriate Microsoft Entra role.

Security Administrator - required to activate the agent the first time and view the agent and take action on the suggestions.

Security Reader and Global Reader - view the agent and any suggestions (can't take actions).

How the agent works

The agent checks for new risky identities that weren't previously identified. If new risky identities are found, it takes the following steps (no SCUs consumed):

The agent checks for new risky users in your tenant who currently have a risk state of "At risk".

The agent identifies risky users that are within your defined scope settings.

If the agent finds new suggestions, it takes the following steps (SCUs consumed):

Step	Agent activity
Investigate the risky user	The agent checks the user's risky sign-ins and risk detections to analyze what's risky about this user.
Generate findings and a risk summary	The agent generates findings based on the investigation, which includes a thorough risk summary explaining the suggestion and defining the key risk factors.
Generate a recommended remediation action	The agent suggests a remediation action, using the information gathered during the investigation.
Answer questions through chat	IT administrators ask the agent questions related to the risky users and the risk summary.
Store custom instructions in agent memory	Customers can give the agent custom instructions through agent chat, which the agent stores in its memory and applies for future runs. Currently, agent memory can store preferred remediation actions.

Using the agent

Sign in to the Microsoft Entra admin center as at least a Security Administrator.

Browse to ID Protection > Risky users.

Look for the banner at the top of the page.

Select Start agent

Configuring agent settings

With the Risky users page open, select the Agent view. Select the ellipses in the upper-right corner and then select Settings.

Controls - provide the roles and permissions needed to run the agent.

Triggers - set when and how the agent is run:

Continuous monitoring - checks for new risky users every 5 minutes

Daily trigger - agent runs once per day

Manual run - agent runs only when manually launched

Scope - By default, the agent investigates the most recent 100 risky users within the last 90 days. You can control the scope of for agent scan by adjusting several options.

Select users and groups option to search for and select the users and groups you want the agent to scan.

Set the maximum recent risky users to scan within 1-100.

Select which risk levels to include in the scan. All risk levels are selected by default.

Set a specific time frame for the scope:

Last 7 days

Last 14 days

Last 30 days

Custom time frame up to 90 days

Communications - enter a set of users to receive notifications of the agent run.

Memory - list of user confirmed safe items that were false positives.

Explore the agent findings report

Agent summary

An agent summary appears at the top of the Agent view, showing recent agent activities. This tile provides quick access to the Chat with agent feature and a Manage agent button, which lets you trigger a one-time run or open agent settings.

Agent suggestions

Agent suggestions are displayed below the agent summary. Hover over a suggestion to highlight impacted users in the table. Selecting a suggestion filters the table to show only those users for review. Each suggestion includes a bulk action button, so you can apply the action with one button.

Currently, the following remediation actions are available in agent suggestions:

Dismiss risk

Reset password

Risky users table with agent suggestions

The lower half of the report lists all risky users. Select a user to view agent findings, risk factors, and suggestions specific to that user. The Agent suggestion column also shows recommended remediation actions directly in the table. Select the action button to apply a remediation to individual users.

Risky user details

The Risky user details page provides a new Agent view, which presents agent findings specific to a risky user. This view includes the following information:

Basic user information: Username, current risk level, and User Principal Name (UPN)

Agent findings: The agent provides a verdict of Compromised or Not compromised based on its investigation

Risk summary: A detailed explanation of the agent's findings, based on analysis of the user's sign-ins and behaviors

Risk factors: Key risk indicators summarized for easy review

Suggested remediation action: A call-to-action button that allows you to quickly start remediating the risk